🧰 Active Directory Denetçisi Araç Kutusu

Bu laboratuvar çalışması sırasında aşağıdaki araçlardan yararlanabilirsiniz.
Araç kullanımı zorunlu değildir.
Amaç araç ezberlemek değil, riskleri tespit etmek ve kanıtlarla desteklemektir.

🔍 Hash Analizi

Hashcat

Parola hashlerinin kırılabilirliğini test etmek için kullanılabilir.
Örnek kullanım:

```
hashcat -m 1000 ntlm_hashes.txt rockyou.txt
```

Kullanılabilecek Modlar:

Hash Türü	Mode
NTLM	1000
MD5	0
SHA256	1400
Kerberoast	13100
AS-REP Roast	18200

John The Ripper

Hash analizinde yaygın kullanılan araçlardan biridir.
Örnek:

```
john ntlm_hashes.txt
```

🔐 Active Directory Analizi

BloodHound

Active Directory ortamındaki yetki ilişkilerini analiz etmek için kullanılabilir.
Araştırılabilecek Sorular:

- Domain Admin'e giden yol var mı?
- Service account'lar risk oluşturuyor mu?
- Privilege escalation mümkün mü?
- Kerberoast sonrası hangi hesaplara ulaşılabilir?

SharpHound

BloodHound veri toplama aracı.
Örnek:

```
SharpHound.exe
```

🛡️ Kerberos Analizi

Impacket Toolkit
Kerberos ve Active Directory analizlerinde yaygın olarak kullanılır.
Araçlar:
- GetUserSPNs.py
- GetNPUsers.py
- secretsdump.py
- smbclient.py
- psexec.py

Kerberoasting
SPN hesaplarını analiz etmek için:

```
GetUserSPNs.py
```

Araştırılabilecek Sorular:
- Hangi hesapların SPN kaydı var?
- Service account parolaları güçlü mü?
- Domain compromise mümkün mü?

AS-REP Roasting
Pre-authentication gerektirmeyen hesapları belirlemek için:

```
GetNPUsers.py
```

Araştırılabilecek Sorular:
- Hangi kullanıcılar AS-REP Roast'a açık?
- Bu hesaplar kritik yetkilere sahip mi?

📊 Log Analizi
Microsoft Event Viewer
İncelenebilecek Event ID'ler:

Event ID	Açıklama
4624	Başarılı giriş
4625	Başarısız giriş
4720	Yeni kullanıcı
4728	Gruba kullanıcı ekleme
4732	Ayrıcalıklı gruba ekleme
4740	Hesap kilitlenmesi

PowerShell
Örnek komutlar:

```
Get-ADUser
```

```
Get-ADGroupMember
```

```
Get-ADComputer
```

```
Get-ADDomain
```

👥 IAM ve Yetkilendirme Analizi

Aşağıdaki sorular değerlendirilebilir:

Joiner

- Yeni kullanıcı açılış süreci var mı?

Mover

- Departman değişikliklerinde yetkiler güncelleniyor mu?

Leaver

- İşten ayrılan hesaplar kaldırılıyor mu?

Privileged Access Management

- Domain Admin sayısı makul mi?
- Service account'lar neden ayrıcalıklı?
- Yetki gözden geçirme süreci var mı?

🌐 Açık Kaynak İstihbaratı (OSINT)

Gerekmesi halinde aşağıdaki araçlar araştırılabilir:

- Shodan
- HaveIBeenPwned
- Dehashed
- CrackStation

Amaç:

- Parolaların daha önce sızdırılıp sızdırılmadığını incelemek
- Kullanılan parolaların yaygın olup olmadığını değerlendirmek

🎯 Bonus Challenge

Aşağıdaki senaryoyu değerlendiriniz:
Bir saldırgan backupsvc hesabının parolasını ele geçirmiştir.
Aşağıdaki sorulara teknik olarak cevap veriniz:

1. Domain Admin yetkisine ulaşabilir mi?
2. Kerberoasting gerçekleştirebilir mi?
3. Lateral movement yapabilir mi?
4. Service account'lar üzerinden yetki yükseltebilir mi?
5. Tüm domain ele geçirilebilir mi?

Kullandığınız varsayımları ve kanıtları raporunuzda belirtiniz.